

Acceso de Usuarios PROVEEDOR al Dashboard SaaS

Resumen

El sistema CRTLPyme ya está completamente configurado para permitir que usuarios con rol **PROVEEDOR** accedan al dashboard de administración SaaS en `/saas-admin`. Este documento explica cómo funciona el sistema de autenticación y autorización para usuarios PROVEEDOR.

Rol PROVEEDOR

Definición

El rol **PROVEEDOR** es el rol de **administrador de la plataforma SaaS**. Los usuarios con este rol tienen acceso completo a:

- Dashboard de administración SaaS (`/saas-admin`)
- Gestión de suscripciones
- Gestión de planes
- Análisis de ingresos
- Visualización de métricas globales
- Gestión de productos maestros
- Administración de tenants

Diferencia con otros roles

- **PROVEEDOR**: Administrador de la plataforma (acceso global)
- **ADMIN**: Administrador de un tenant específico
- **CAJA**: Operador de punto de venta
- **INVENTARIO**: Encargado de gestión de inventario
- **SOPORTE**: Soporte técnico

Verificación de Acceso Actual

El sistema ya implementa las siguientes verificaciones para usuarios PROVEEDOR:

1. Middleware de Rutas (`middleware.ts`)

```
export const config = {
  matcher: [
    '/saas-admin/:path*', // Protege todas las rutas de saas-admin
    // ... otras rutas
  ],
}
```

2. Layout del Dashboard (`app/saas-admin/layout.tsx`)

```
// Líneas 45-48
if (status === 'authenticated' && session?.user?.role !== 'PROVEEDOR') {
  router.push('/dashboard');
  return;
}

// Líneas 62-64
if (session?.user?.role !== 'PROVEEDOR') {
  return null;
}
```

3. Páginas del Dashboard (`app/saas-admin/page.tsx`)

```
// Líneas 44-47
if (session.user.role !== 'PROVEEDOR') {
  router.push('/dashboard');
  return;
}
```

4. API Routes (`lib/admin-auth.ts`)

```
export async function verifyAdminSaaSAccess() {
  const session = await getServerSession(authOptions);

  if (session.user.role !== 'PROVEEDOR') {
    return {
      error: NextResponse.json(
        { error: 'Acceso denegado. Solo administradores SaaS pueden acceder a este re-
curso.' },
        { status: 403 }
      ),
      session: null,
    };
  }

  return { error: null, session };
}
```

Todas las rutas API bajo `/api/admin-saas/*` utilizan esta función para verificar el acceso.



Cómo Usar el Sistema

Para Usuarios PROVEEDOR Existentes

1. Iniciar Sesión

- Navegar a `/auth/login`
- Ingresar credenciales de cuenta PROVEEDOR existente
- El sistema automáticamente redirigirá al dashboard apropiado

2. Acceder al Dashboard SaaS

- Una vez autenticado, navegar a `/saas-admin`
- El sistema verificará el rol y permitirá el acceso
- Se mostrarán todas las funcionalidades de administración SaaS

3. Funcionalidades Disponibles

- /saas-admin - Dashboard principal con métricas
- /saas-admin/subscriptions - Gestión de suscripciones
- /saas-admin/plans - Gestión de planes
- /saas-admin/revenue - Análisis de ingresos

Para Crear Nuevos Usuarios PROVEEDOR

IMPORTANTE: Los scripts de seed ya NO crean cuentas PROVEEDOR automáticamente para evitar duplicados.

Opción 1: Crear manualmente en la base de datos

```
-- Primero, crear un tenant para el administrador (o usar uno existente)
INSERT INTO tenants (id, "businessName", rut, email, "isActive", "planType", "max-
Cashiers")
VALUES ('admin-tenant-id', 'Administración CRTLPyme', '99.999.999-9', 'ad-
min@crtlpyme.com', true, 'ENTERPRISE', 999);

-- Luego, crear el usuario PROVEEDOR
-- NOTA: La contraseña debe ser hasheada con bcrypt
INSERT INTO users (id, email, password, "firstName", "lastName", role, "isActive", "te-
nantId")
VALUES (
  'proveedor-user-id',
  'nuevo.admin@crtlpyme.com',
  '$2a$12$[hash_de_bcrypt]', -- Hash de la contraseña
  'Nombre',
  'Apellido',
  'PROVEEDOR',
  true,
  'admin-tenant-id'
);
```

Opción 2: Crear mediante script Node.js

```
const bcrypt = require('bcryptjs');
const { PrismaClient } = require('@prisma/client');

const prisma = new PrismaClient();

async function createProveedorUser() {
  const hashedPassword = await bcrypt.hash('contraseña_segura', 12);

  // Crear o usar tenant existente
  const adminTenant = await prisma.tenant.upsert({
    where: { rut: '99.999.999-9' },
    update: {},
    create: {
      businessName: 'Administración CRTLPyme',
      rut: '99.999.999-9',
      email: 'admin@crtlpyme.com',
      isActive: true,
      planType: 'ENTERPRISE',
      maxCashiers: 999
    }
  });

  // Crear usuario PROVEEDOR
  const proveedorUser = await prisma.user.create({
    data: {
      email: 'nuevo.admin@crtlpyme.com',
      password: hashedPassword,
      firstName: 'Nombre',
      lastName: 'Apellido',
      role: 'PROVEEDOR',
      isActive: true,
      tenantId: adminTenant.id
    }
  });

  console.log('Usuario PROVEEDOR creado:', proveedorUser.email);
}

createProveedorUser();
```



Seguridad

Verificaciones de Seguridad Implementadas

1. Autenticación mediante NextAuth

- JWT tokens con claims personalizadas
- Sesiones seguras

2. Autorización basada en roles

- Verificación en middleware
- Verificación en componentes del cliente
- Verificación en API routes

3. Protección de rutas

- Rutas `/saas-admin/*` requieren autenticación

- Solo rol PROVEEDOR puede acceder
- Redirección automática si no autorizado

4. Aislamiento de datos

- Las consultas incluyen `tenantId` para multi-tenencia
- PROVEEDOR puede ver todos los tenants
- Otros roles solo ven datos de su propio tenant



Rutas API Protegidas

Todas las siguientes rutas API requieren rol PROVEEDOR:

- GET `/api/admin-saas/metrics` - Métricas del sistema
- GET `/api/admin-saas/stats` - Estadísticas generales
- GET `/api/admin-saas/tenants` - Lista de tenants
- GET `/api/admin-saas/tenants/[id]` - Detalle de tenant
- PUT `/api/admin-saas/tenants/[id]` - Actualizar tenant
- POST `/api/admin-saas/tenants/[id]/activate` - Activar tenant
- POST `/api/admin-saas/tenants/[id]/suspend` - Suspenden tenant
- PUT `/api/admin-saas/tenants/[id]/change-plan` - Cambiar plan
- GET `/api/admin-saas/master-products` - Productos maestros
- POST `/api/admin-saas/master-products` - Crear producto maestro
- PUT `/api/admin-saas/master-products/[id]` - Actualizar producto
- DELETE `/api/admin-saas/master-products/[id]` - Eliminar producto



Cambios Realizados

Scripts de Seed Modificados

Para evitar crear cuentas PROVEEDOR duplicadas, se han comentado las siguientes secciones:

1. `scripts/seed.ts` (líneas 65-82)
 - ❌ Usuario `john@doe.com` ya no se crea
2. `prisma/seed-multitenancy.ts` (líneas 46-66)
 - ❌ Usuario `admin_saas@crtlpyme.cl` ya no se crea
3. `prisma/seed-complete.ts` (líneas 414-447)
 - ❌ Usuario `admin@crtlpyme.com` ya no se crea

Razón del Cambio

Los scripts de seed estaban creando cuentas PROVEEDOR innecesarias cada vez que se ejecutaban, lo que causaba:

- Duplicación de cuentas
- Confusión sobre qué cuenta usar
- Potenciales problemas de seguridad

Solución: Las cuentas PROVEEDOR existentes en la base de datos ya tienen acceso completo al dashboard SaaS. No es necesario crear nuevas cuentas en cada seed.

✓ Verificación de Funcionamiento

Para verificar que un usuario PROVEEDOR tiene acceso correcto:

1. Verificar rol en la base de datos

```
SELECT email, role, "isActive" FROM users WHERE role = 'PROVEEDOR';
```

1. Iniciar sesión con credenciales PROVEEDOR

2. Intentar acceder a /saas-admin

- ✓ Debe mostrar el dashboard
- ✓ Debe mostrar métricas y estadísticas
- ✓ Debe permitir navegación a subcategorías

3. Verificar API access

```
# Con token de sesión válido
curl -X GET http://localhost:3000/api/admin-saas/stats \
-H "Cookie: next-auth.session-token=TOKEN"
```

Notas Adicionales

Base de Datos

- El rol está definido en el enum `UserRole` en el schema de Prisma
- El campo `role` en la tabla `users` almacena el rol del usuario

Redirección Automática

- Si un usuario no-PROVEEDOR intenta acceder a `/saas-admin`, es redirigido a `/dashboard`
- Si un usuario PROVEEDOR inicia sesión, puede navegar libremente a `/saas-admin`

Desarrollo Local

- Asegúrate de tener al menos una cuenta PROVEEDOR en tu base de datos de desarrollo
- Si no tienes ninguna, usa uno de los métodos descritos arriba para crear una

Resolución de Problemas

Problema: Usuario PROVEEDOR no puede acceder a /saas-admin

Solución:

1. Verificar que el usuario existe en la base de datos
2. Verificar que `role = 'PROVEEDOR'`
3. Verificar que `isActive = true`
4. Limpiar cookies del navegador e iniciar sesión nuevamente

Problema: Error 403 en API routes

Solución:

1. Verificar que la sesión está activa
2. Verificar que el token JWT contiene el rol correcto
3. Verificar logs del servidor para más detalles

Problema: Scripts de seed fallan

Solución:

- Los scripts de seed ya no crean usuarios PROVEEDOR
- Si necesitas datos de prueba, crea el usuario PROVEEDOR manualmente primero
- Luego ejecuta los scripts de seed para crear tenants y datos de prueba



Referencias

- **Código de autenticación:** `lib/auth.ts`
 - **Verificación de acceso:** `lib/admin-auth.ts`
 - **Middleware:** `middleware.ts`
 - **Layout SaaS Admin:** `app/saas-admin/layout.tsx`
 - **Schema de base de datos:** `prisma/schema.prisma`
-

Última actualización: Noviembre 2025

Versión del documento: 1.0